DOCUMENT REVIEW / ENGINEERING RECOVERY

cv-agent

设计审查与工程修复方案

设计理念与逻辑诊断 / 已知阻断与潜在 bug
实施任务卡 / 回归规格与发布门槛

核心判断
先形成稳定、可交付的审查路径；再证明模型、规划与多专家带来的增量。保留证据门槛，不用更多调用掩盖环境和控制流的硬缺口。

审查依据	用户提供的 43 页项目技术报告，记录日期 2026-09-30
报告基线	`4dba622db459d4487bc8493b9af3a6a5f40a3387`
审查条目	14 项设计与交付问题 + 9 项待源码验证风险
实施规格	15 张任务卡 + 34 项回归验收规格
结论边界	未取得实际源码、配置或原始日志；未复跑项目、模型或目标验证

2026 年 9 月 30 日 技术审查稿 v1.0

本报告区分来源事实、条件推导与待验证假设。它是修复计划，不是已实施补丁，也不是项目已经修复的验收证明。

目录

1　执行结论：先修交付路径，不要继续堆叠推理层　1

2　审查依据、结论强度与因果诊断　3

3　设计与交付问题清单　5

4　待源码验证的潜在 bug　10

5　目标设计：保留可信内核，建立两条互不绑死的交付路径　13

6　实施任务书：一次只完成一个可验收变更　16

7　回归规格与发布门槛　24

8　交给执行模型的工作指令　27

9　来源索引与最后结论　29

阅读路线

负责人先读第 1、2、7 章；架构与代码审查者重点读第 3–5 章；执行模型从第 6 章单张任务卡开始，用第 7 章回归矩阵验收。第 9 章提供来源定位。

R = 原报告记载；D = 设计推导；H = 待源码验证。P0/P1/P2 为工程优先级，不是漏洞评分。

1　执行结论：先修交付路径，不要继续堆叠推理层

1.1　总判断

cv-agent 不是“所有代码都无法运行”，而是“部分工程机制可运行，核心自主目标未成立，普通使用路径尚未形成可验收价值”。原报告记录了受控开发见证、环境重建和 2562 项通过的测试日志；同时明确记录 M0 与 E-iter 没有建立模型自主确认正例、合格外部配对为 0、正式 G-A=NO。两组事实必须同时成立，不能只选其中一组解释项目。[R §1.2、§16，PDF 7、32–34 页]

最需要修复的不是某个检索公式，而是职责分配与实施顺序。目前的主链先要求一个复杂候选审查系统同时满足检索、规划、工具协议、环境、证据、投票与研究记账，最后才交付有用结论；目标环境的硬限制、模型协议的不稳定和证据本身的能力边界，会在同一条链上叠加。原报告对“不应夸大结果”的约束较成熟，但对“即使不能完成高级证明，也能稳定完成一项实际审查工作”的产品路径，没有提供同等级别的完成证据。后一判断属于本次审查的设计推论，不是对缺失源码的复现结论。[R 图 1–3，PDF 9、18、23 页；§18，PDF 35–36 页]

建议采取**保留可信内核、建立窄而完整的产品主路径、隔离可选研究能力**的方案，而不是全量推倒重写。第一交付物应是：仅给出已授权本地源码，就能稳定输出位置、静态事实、证据范围、明确缺项和人工复核建议；不需要 API key，也不需要运行目标源码。批准夹具的有界验证作为单独能力接入。模型、多专家和 Jev 的地位改为“须证明增量的可选模块”，不是所有结果出门前的必经环节。

这不是把“通用自动漏洞验证”偷换成一个简单扫描演示。原目标仍然未完成，G-A 仍应保持 NO。新路径只是先建立一个可以独立验收的交付基线；能否产生真实用户价值，还要用后文的人工审查工作量与质量指标检验。

1.2　五项应立即拍板的决定

决定	原因	对应任务
先建立无需模型的完整静态审查入口	防止任何可选能力失败都变成“项目没有输出”	T01–T04
把环境与能力预检前移	已确认的临时目录、native 缺项不应再由模型循环发现	T02、T10、T11
新产品不以 quorum 决定性质事实	两个模型解读同一份证据，不等于增加证据	T06
关闭新产品的自动早停，先验证全局证据一致性	固定票多数不变，不代表新观察不会使旧票失去准入	T06、T13
暂停新增路由、多专家与昂贵试验	先修输入到产物闭环；新调用必须有独立授权和可测目标	T13、T14

以上是新的实施建议，不追溯修改 E1–E5、原预算、原实验来源或原 G-A。现有“未知保持未知”“错误不能解释为安全”“预算不能降低证明门槛”等原则继续保留。[R §1.3、§8、§13.4、§16.4，PDF 7、18–20、28、33–34 页]

1.3　硬事实与不能据此推出的结论

原报告记录	可以推出	不能推出
M0 与 E-iter 共 72 次请求、447812 reported tokens	这轮已发生明显的模型试验投入	72 个独立样本、所有模型都无能、必须加预算
E-iter 四格全部弃权，每格一次物理场景	该轮没有完成预期的模型自主迭代	重复调用去重一定有 bug，或固定侧已安全
callback 在临时目录处失败	存在具体环境阻断 F4	该入口不存在问题，或模型场景选择一定错误
外部合格配对为 0	本轮环境准备未完成外部验收	外部项目永远不可构建或不可分析
两张实质票共享一份原始见证	共享观察计账机制已做开发控制	两份统计独立证据或多专家增益已经成立
2562 项测试通过的归档日志	已有较大规模的受控回归体系	端到端产品可用、全 Python 语义完备或盲测有效

来源：R §12.3、§16–17，PDF 27、32–35 页。请求与 token 合计已按表 12 复核：32+14+26=72，191177+90153+166482=447812。本次没有复跑原项目、原测试或任何模型实验。

2　审查依据、结论强度与因果诊断

2.1　材料与审查边界

唯一项目材料是用户提供的《**cv-agent 技术报告：当前系统设计、逻辑与流程**》，记录日期 2026-09-30，共 43 个 PDF 物理页。报告基线为 `4dba622db459d4487bc8493b9af3a6a5f40a3387`，另说明存在收尾状态更新。本次逐页核对了文本与页面图表，重点检查表 12–14 的运行结果，以及图 1 的主链、图 2 的准入链、图 3 的见证链。[R 封面、§19，PDF 1、37 页]

没有取得实际源码、依赖锁、原始 JSONL、配置或 `.hermes` 验收文件。原报告列出的这些文件只是本次定位依据，不等于已经被独立阅读。因此本报告能确认 “原报告记载了什么” 和 “某条设计规则在什么条件下会出问题”，不能宣称某行真实代码已经被本次复现或修复。

本报告另核对了少量官方技术文档，见文末 W1–W8。它们只用于校验 frozen、图步数、临时目录、隔离、构建与测试跳过等机制；不用于替换项目事实。文档检索日期为 2026-09-30，实际修改仍以项目锁定版本为准，不建议顺手升级框架。

标记	含义	使用规则
R	原报告明确记载	是来源事实，尚不等于本次独立复现
D	从契约推导的设计问题	给出成立前提、后果和反例，不伪装为源码事实
H	需要源码验证的潜在 bug	先写回归，证伪后保留记录，不强行修改
P0	阻断目标交付或必须优先排除的证据完整性风险	是工程优先级，不是漏洞严重性评分
P1 / P2	下一阶段重要修复 / 条件触发检查	不代表一定已经发生

后文列出 **14 项设计与交付问题、9 项待验证代码风险、15 张实施任务卡和 34 项回归规格**。问题编号不代表 23 个已确认代码缺陷；任务也不是已经提交的补丁。

2.2　原报告中的设计理念：哪些应保留

候选身份绑定到源码、位置、性质、范围和前提；观察、证明与最终标签分开；未解析语义保留未知；预算不改变证据门槛；工程验收与研究结论分开。这五点是项目最值得保留的部分，不能为了 “跑出正例” 拆掉。源码边界读取、原始观察计账、错误与未知分离、先记 usage 后解析响应，也具有明确工程价值。[R §1.3、§3、§7–8、§12.3–13，PDF 7、10–12、16–20、27–28 页]

本次批评的焦点不是这些原则过于严格，而是**谁负责执行这些原则，以及原则约束之外是否还留有一条稳定交付路径**。例如，工具前提没准备好应由控制器阻塞并说明，不应要求模型通过一连串自由行动自行发现；充分证据是否成立应由确定性准入决定，不应因第二位解释者没有投出同一票而消失。

2.3　五个层次必须分别诊断

层次	问题	当前能确认的状态	修复责任
启动与配置	入口是否可调用、配置是否可解析	报告有 CLI 与 runner；用户本地启动错误未提供	应用层、安装与 doctor
能力与环境	所需工具、入口、临时目录和构件是否可用	有明确 F4 与 native 准入失败	运行时与准备层
协议执行	准备、调用、反馈、终止是否完整	有准备未完成与无第二次物理场景	状态机与控制器
性质证据	当前方法能否支持声明性质	有界、只支持部分性质；正向见证不提供 SAFE	分析器与准入层
产品与研究	输出是否帮助用户、能否形成泛化结论	核心自主目标未成立；产品验收缺证	产品协议与评价层

来源：R §1.2、§6–10、§14、§16–18，PDF 7、15–25、28–30、32–36 页。不能把所有问题笼统归为 “模型弱”，也不能把所有 UNKNOWN 都当作基础设施故障。

2.4　为什么堆功能没有自然带来可用性

原图 1 将检索、规划、专家工具循环、准入和投票串接；图 2 进一步加上身份、投递、范围和冲突门槛；图 3 的正向见证又增加入口、环境、源码库存、义务与对照。[R 图 1–3，PDF 9、18、23 页]

对一个必须经过这些阶段的成功事件 U，可以用条件概率链理解瓶颈：

$$P(U) = P(D)\,P(C \mid D)\,P(E \mid D, C)\,P(J \mid D, C, E)\,P(O \mid D, C, E, J).$$

这里 D 为得到合适候选，C 为所需能力就绪，E 为产生足够证据，J 为正确接纳，O 为正确交付。这个分解不假设各阶段独立，也没有给当前项目填入未经测量的概率。它说明：**前面某一阶段实际不可用时，后面的专家再多，也不能补足那一阶段**。因此应测量各阶段转换率和阻断原因，而不是只看最终 ABSTAIN。

另一个瓶颈是证明方向不对称。存在性结论可以由一个满足前提的完整实例支持；全范围否定需要覆盖所声明的所有相关情况。正向 witness 只提供 CONFIRMED，因此 “增加几次没有观察到事件的运行” 不会自然得到 REFUTED。把固定侧未决当成验证器失败、或者逼模型投 SAFE，都会破坏原设计正确的证据边界。[R §8.3、§10.1、§15.1，PDF 19、22、30–31 页]

3　设计与交付问题清单

本章优先讨论能够从报告建立依据的问题。每项分别列出事实、逻辑、修改方案与验收，避免把 “已明确的能力边界” 写成未知代码 bug。执行顺序以第 6 章任务依赖为准，而不是按出现顺序一口气重写。

3.1　D01 ｜目标就绪没有成为模型调用之前的强制业务门禁

优先级：P0　依据：R + D　执行任务：T02、T04、T13

已知事实。报告明确区分 import ready 与分支可执行；近迁移 callback 的正确离线脚本也在临时目录创建处失败。E-iter 仍对这两格发生了模型调用。外部候选则因原生扩展缺失，未完成环境准入。[R §10.6–10.7，PDF 24–25 页；§16.4，PDF 33 页]

问题逻辑。当前全量 pytest 门禁回答的是 “检测器代码能否进入实验”，不是 “这次目标和所需能力是否可用”。把两者串成一个泛化的 ready，或者只向使用者显示测试通过，会让环境问题在昂贵的模型循环里才暴露。原报告的专项规则并非完全没有准备检查，问题是该检查尚未构成统一的产品入口契约。

建议修改。新增按本次任务所需能力计算的 preflight；先做静态能力检查，再对明确注册的自有验证夹具做无害功能预检。区分环境可用、入口可用、验证器可用与证据已成立。准备缺口直接产生结构化诊断，静态报告仍可交付，不启动注定不可执行的模型或 worker 路径。

最低验收。删除批准测试环境中的一个必要依赖：预检应返回具体缺项、对应能力不可用、模型请求数为 0。补回依赖后，同一无害预检通过；不能把 “未运行验证” 计为安全。

3.2　D02 ｜只读执行边界与正常临时目录需求发生确定冲突

优先级：P0　依据：R　执行任务：T10

已知事实。 callback 两格在到达候选帧之前，就因临时目录不可用而中止。报告把它归为 F4，并已列出 worker 私有临时目录作为待批准扩展。[R §9.6，PDF 21–22 页；§16.2–16.4，PDF 33 页；§18.3，PDF 36 页；W3、W4、W5]

问题逻辑。这不是模型不够聪明，也不是被检查代码已经安全，而是允许的执行环境不包含该正常入口必需的能力。只修改 TMPDIR 字符串也不充分：文件系统控制、继承描述符、资源额度和清理生命周期必须一起匹配。

建议修改。在独立、显式批准的隔离 profile 中，为每个 worker 预分配私有 scratch；仅该目录内允许所需临时读写，源码、依赖和宿主其他位置保持只读或不可访问。所有权、容量、文件数、回收和并发隔离由运行时负责；不得让模型选择宿主写入路径。保留旧只读 profile，禁止直接放开整个 /tmp。

最低验收。项目自有无害夹具在私有 scratch 内完成创建、读取、删除；写到工作区外必须失败。两个并发 worker 不能读到彼此内容；正常退出、超时和异常退出后均无残留。操作系统缺少必要隔离能力时拒绝该 profile。

3.3　D03 ｜ metadata-only 环境准备没有覆盖目标自身原生扩展

优先级：P1　依据：R　执行任务：T02、T11

已知事实。唯一符合源码路径标准的暂定外部候选缺少对应版本的目标 native 扩展，合格外部配对为 0。报告也明确说明，这不证明该源码不可构建。[R §10.6–10.7，PDF 24–25 页；§16.4，PDF 33 页；W6、W7]

问题逻辑。包的 metadata、纯 Python 源码可导入、目标二进制可加载，是不同的交付物。环境准备策略没有产生必要扩展时，继续研究路由、投票或提示词不会修复这个缺口。

建议修改。立即把需要未提供 native 构件的能力标记为 UNSUPPORTED 或 BLOCKED，避免进入验证链。后续为批准的自有测试包增加独立构建步骤：锁定源码、构建依赖、编译器和平台；记录 wheel 与扩展摘要、ABI 和加载路径。构建依赖隔离不能冒充运行恶意源码的安全沙箱。构建必须在专用受限环境完成，不能由 agent 临时安装或升级。

最低验收。用只返回固定常量的自有扩展包验证构建与导入链；替换为不匹配 ABI 或另一构件摘要必须拒绝。没有编译器时输出可理解的缺项，不静默采用另一版本二进制。

3.4　D04 ｜协议推进过度依赖模型自觉，能力试验与控制器可靠性混在一起

优先级：P0　依据：R + D　执行任务：T04、T07

已知事实。M0 有未完成准备的格子；E-iter 四格均只发生一次物理场景执行，完整反馈到达后没有模型驱动的第二次场景执行。离线脚本能够容纳两次不同场景，不等于真实模型会主动完成协议。[R §7.1–7.5，PDF 16–18 页；§10.2–10.3，PDF 22 页；§16.2–16.3，PDF 32–33 页]

问题逻辑。事实只证明流程没有产生预期迭代，不能直接证明是某一提示词、重复调用抑制或模型能力单独造成。问题在于 “准备是否完整、应向谁请求缺项、何时停止、是否必须生成可读报告” 等确定性职责仍受自由模型行动影响。

建议修改。把 PREPARING、WAITING_INPUT、READY、RUNNING、FINISHED、BLOCKED 分成可测控制状态。运行时推进已知协议；模型只解释现有静态事实和整理缺项。对未提供的业务前提转交使用者，不让系统自动生成攻击场景或试探第三方目标。无新增信息时结束并输出下一步，而不是鼓励模型反复给出同一实质标签。

最低验收。scripted 模型连续两次给出同一无效动作时，流程在预设界限内收尾、保留缺项，模型调用数不超限。人工补入一个已批准的无害输入后，能够从等待态恢复；日志清楚区分协议恢复与新物理执行。

3.5　D05 ｜见证前置依赖可能把独立静态事实一起阻塞

优先级：P1　依据：D　执行任务：T07、T13

已知事实。政策可以生成独立 witness 任务，并使后续命令分析依赖其完成；未完成必需验证器会传递阻塞，最终弃权。[R §6.3–6.4，PDF 15–16 页；§7.4，PDF 17 页]

问题逻辑。当静态检查确实需要见证输出时，依赖是正确的。但若它只需要源码，调度顺序被误当成数据依赖，环境 F4 就会阻止本可产生的静态报告。由文档不能确认哪些具体计划属于这种情况，必须逐类检查 policy。

建议修改。区分数据依赖、展示顺序和某类最终 claim 的必要义务。独立静态任务不依赖可选执行成功；高级 claim 仍受其必需验证器约束。可选验证失败只降低这项 claim 的完成度，不清空已经得到的事实。禁止为追求 completed 而把原有强 claim 的必要验证器改成可选。

最低验收。构造一个源码检查任务和一个与其无数据依赖的不可用验证任务：前者仍完成并进入报告，后者显示 F4；整体显示部分完成且不得出现未经证明的 VULNERABLE 或 SAFE。

3.6　D06 ｜按任务数量均分观察预算，可能让可完成的计划局部不可完成

优先级：P1　依据：D　执行任务：T08

已知事实。默认同一专家共享 8192 字节观察预算；第 k 个任务累计上限按任务份额开放。截断证明失去准入资格，已经完成的重复物理调用又会被抑制。compact 已缓解部分见证载荷问题，但不是一般预算可行性证明。[R §5.4，PDF 14 页；§7.2–7.4，PDF 17 页；§10.8，PDF 25 页]

问题逻辑。构造性反例：同专家 4 个任务，首任务的最小合法证明封装为 2500 字节，其他各 1000 字节。总需 5500，小于 8192；首份额度却仅为 2048，合法证明可能在首任务被截断。这些载荷大小是本审查的假设，不是原项目实测值。

建议修改。规划时计算必需工具最小证书尺寸并做可行性检查；先保留必需结果和最终诊断空间，再分配可选观察。允许受控借用尚未消费的共享预算，但总上限不变。将 “重新投递已有证书” 与 “重新执行工具” 分开记账；重新投递同样消耗字节，不增加物理验证次数。

最低验收。上述 5500 字节计划在总预算内能得到完整证书；当预算低于所有必需证书之和时，在执行前报告不足。测试引用、JSON 转义和外层字段全部参与实际序列化计量。

3.7　D07 ｜用户价值过度集中在最终三值标签，缺少明确的审查交付层

优先级：P0　依据：R + D　执行任务：T03、T01、T13
已知事实。报告记录了丰富的证据、gap、轨迹和用量；M0 阶段 1 与 E-iter 的格子全部弃权，阶段 2 重跑仍未确认。报告没有展示一个普通使用者仅提供本地源码后，可以直接完成审查工作的产品验收记录。已有 cli.py 和候选 runner，不能据此断言项目没有入口。[R §3.4，PDF 11–12 页；§14.2，PDF 29 页；§16.2，PDF 32–33 页；§18.1–18.2，PDF 35–36 页]
问题逻辑。“不能确认漏洞”不等于“没有可用信息”；反过来，内部保存大量信息也不等于使用者拿到了一份可行动报告。若交付只突出 ABSTAIN，源码位置、已知事实、未解决义务和下一位责任人就难以转化为实际价值。
建议修改。增加不依赖模型与目标执行的静态审查输出：位置、性质、已建立事实、未覆盖范围、缺项原因、建议人工检查点和证据链接。模式命中只能写“待复核线索”，不能冒充发现漏洞。保留原 y/v 与实验计分，在新的产品视图中单独展示工作进展与证据强度。
最低验收。没有 API key、执行隔离不可用、或模型响应失败时，已完成静态分析仍能产生有效 JSON 和人类可读报告；零候选、解析失败、能力不支持分别显示，不以空文件或整体 SAFE 代替。

3.8　D08 ｜ quorum 聚合的是解释次数，不能替代证据充分性或独立性

优先级：P1　依据：R + D　执行任务：T06、T13
已知事实。 E4/E5 默认需要两张实质票；单张 CONFIRMED 不增加票权。K4 的两票共享同一原始见证，原报告已正确记录为共享票 2、原始观察 1。[R §6.2，PDF 15 页；§12.1–12.3，PDF 26–27 页]
问题逻辑。同一份充分证据经一个解释者产生弃权、经两个解释者才获 quorum，是聚合政策选择，不是证据新增。若验证器与准入已决定证据是否充分，额外模型主要增加解释、格式与适用性失败点。报告并未证明三专家相对单专家的净收益。
建议修改。保留 E1–E5 为历史研究配置。新增独立产品 profile，由确定性 evidence reducer 形成性质判断；模型只编写可核验解释，额外专家仅作为可选复核。原始生产者计数不得因复制引用增加；不把平均 confidence 展示为真实正确概率。
最低验收。复制同一观察给多个角色，证据结果和物理观察数保持不变；新增一份真正独立的物理执行只增加执行计数，并不自动消除同范围冲突。旧 E4/E5 的投票回归不受新 profile 影响。

3.9　D09 ｜性质确认与应用漏洞标签之间仍存在接口误读风险

优先级：P1　依据：R + D　执行任务：T01、T06
已知事实。见证只支持正向 CONFIRMED，不支持 REFUTED/SAFE；`remote_authority_established=false`；直接 callback 不覆盖公开 CLI parser。权限位证明、eval 切片探针和命令消费见证具有不同证明范围。[R §1.1，PDF 7 页；§3.3–3.4，PDF 11–12 页；§9.3–9.5，PDF 21 页；§10.1–10.4，PDF 22–23 页]
问题逻辑。这些限制写得清楚，不能指控原报告已经宣称全应用安全。但通用 VULNERABLE/CONFIRMED 字段被下游只看标签时，仍可能把“声明条件下某局部性质成立”误读成“现实部署可被利用”。command-execution 的具体逻辑谓词尤其应机器可读，而非仅靠 scope note。
建议修改。给每个 property 增加版本化谓词定义、量词、适用输入域、证明层级和不覆盖项。产品文案显示“该范围内性质得到支持”，不自动推导远程权限或漏洞影响。未观察到事件继续 UNKNOWN；要做否定判断，必须使用支持相应范围否定证明的其他方法。
最低验收。同一 CONFIRMED 状态换成不匹配的 property 或范围必须拒绝；字面量见证不能变成 SAFE；callback 证据的导出结果必须持续显示公开入口与远程权限未评估。

3.10　D10 ｜冻结的检索路径适合消融，不宜直接成为所有产品任务的知识边界

优先级：P1　依据：R + D　执行任务：T09、T05
已知事实。admitted paths 取自最终投递文档，工具不能把 local 系统扩成全仓检索。graph/hybrid 有各自 top-k 语义和共享字节预算；图边不证明动态可达。[R §5.1–5.5，PDF 13–15 页；§9.2，PDF 20 页]
问题逻辑。对 E 系列公平比较，这个限制是必要约束。对真实静态审查，初始检索遗漏一个已明确引用的 helper 后，又禁止读取它，可能使缺口永久存在。简单把默认 top-k 调大既不保证相关性，也会增加成本。
建议修改。旧实验继续冻结。新产品仅在已授权源码根内提供显式、预算化的静态上下文扩展：记录请求原因、读取范围、实际投递和拒绝原因；超预算就保留缺口。源码快照身份与检索视图版本分离，避免合法扩展后所有既有证据因索引变化失效。不得通过扩展读取评价标签或受保护目录。
最低验收。初始上下文缺少一个无害 helper，允许的一次扩展能获取它且被完整计费；预算不足或路径未授权则拒绝。E1–E5 的原始 admitted paths 与预算仍严格不变。

3.11　D11 ｜全量测试门禁正确，但生命周期位置导致冷启动成本过重

优先级：P1　依据：R + D　执行任务：T03、T12
已知事实。同一进程首次 live 请求前执行完整 pytest，状态仅在进程内保存；现有日志为 400.78–433.32 秒，约 6.7–7.2 分钟。不是每个请求都跑全量测试，也不能把本地日志当可复用 pass stamp。[R §13.1–13.2，PDF 27 页；§16.1，PDF 32 页；§17.1，PDF 34 页]
问题逻辑。将实验准入保留在传输层很保守，但普通用户把这种冷启动等待感知为 “运行不起来” 是合理的产品风险。更重要的是，付出全量测试时间仍不能保证本次目标具备运行前提。
建议修改。第一阶段不改现有 live 门禁；离线静态产品根本不调用 provider。已获授权的批量实验尽量在同一受门禁约束进程内完成，并显示独立进度。以后若引入发布构件与受信测试凭据，需要另立版本化政策与完整身份校验，不能现在凭缓存日志绕过旧规则。
最低验收。doctor 与离线审查没有模型请求；同进程两次授权 live 调用只执行一次完整准入，指纹变化仍立即拒绝。所有耗时拆分为准备、门禁、模型、工具和输出，不隐藏门禁成本。

3.12　D12 ｜产品编排仍围绕实验组织，缺少稳定的应用服务边界

优先级：P1　依据：R + D　执行任务：T00、T03
已知事实。evaluation 有 107 个模块，负责较多配置、准备、执行与生命周期；核心已不反向导入 evaluation，K2 的边界修复不能被当成尚存循环依赖。模块数量不是代码质量或覆盖率证据。[R §2.2–2.3，PDF 8–10 页；§14.1–14.3，PDF 28–29 页；附录 A，PDF 38–39 页]
问题逻辑。风险不在 “107 太多”，而在正常使用路径是否必须理解实验格子、数据角色、授权账本和历史配置。项目已经有 AgenticPipeline 与 run_candidate，适合提取薄应用入口，而不是重新发明一套 agent 框架。
建议修改。新增薄 application 服务，复用 domain、检索与工具；对外接受本地快照和显式产品 profile，返回稳定结果。evaluation 成为该服务的研究调用者。禁止一轮迁移整个 evaluation，也不为目录整齐移动已稳定的见证内核。先证明主路径可用，再删除确有重复的组装代码。
最低验收。新增应用服务在不读取 evaluation 数据集、不读取.hermes 历史状态的情况下完成无害源码审查；现有核心到 evaluation 的导入边界测试继续通过。

3.13　D13 ｜发现范围大于可验证范围，能力协商应先于任务规划

优先级：P1　依据：R + D　执行任务：T02、T01、T07
已知事实。扫描器生成多种候选，多语言适配器有不同层级；非 Python flow 含近似，witness 性质固定，权限验证也只支持特定性质。固定专家集合或 applicable_v1 不会自动补齐缺少的验证能力。[R §4.1–4.2，PDF 12–13 页；§6.2–6.3，PDF 15–16 页；§9，PDF 20–22 页]
问题逻辑。“能解析文件”“能发现模式”“能做有界静态判断”“能完成某种证明”是四个能力，不能合为一个 supported。若在规划后才发现性质没有验证器，会消耗预算并产生形式完整、内容空洞的任务。
建议修改。引入按语言、property、scope、方法与环境计算的 CapabilityDecision。支持不足仍输出线索，但不调度不可能完成的验证任务；能力不足与真实语义 UNKNOWN 分开记。首个产品版本声明支持矩阵，而不是默认宣称通用多语言漏洞验证。
最低验收。同一语言中不同性质得到不同能力决策；缺少某验证器不影响纯源码索引；一个不适用 authz 专家不会为了凑两票被强行安排实质判断。

3.14　D14 ｜研究门槛与产品完成度不能继续互相代替

优先级：P1　依据：R + D　执行任务：T13、T14
已知事实。正式 G-A 的两个合取条件都不满足；外部合格配对为 0；部分 held-out 元数据已暴露。原报告明确区分工程验收、运行完整性和研究 claim readiness，这一点应保留。[R §14.4–15.3，PDF 29–31 页；§16.4–18.3，PDF 33–36 页]
问题逻辑。既不能用 2562 项测试通过证明产品有用，也不能用 G-A=NO 否定一切静态审查价值。当前真正缺少的是独立产品验收：用户输入、可交付输出、时间预算、支持范围和人工节省效果。72 次模型请求不是 72 个独立样本；零观察成功也不是对所有模型和所有目标成功概率为零的证明。
建议修改。G-A 及所有历史结果保持原样，新增 GP 系列产品门槛。先测无模型端到端交付，再测批准能力的可用性，最后测模型对同一静态审查流程的增量。新的研究结论使用事前冻结的新材料、独立评价者与明确统计单位。
最低验收。缺失、弃权、失败和未运行都保留在各自分母；受污染数据不能因重命名重新成为盲测。只增加调用次数而没有改善报告质量或人工耗时，不计作里程碑完成。

4　待源码验证的潜在 bug

下列 H 项不能据文档直接定案。每一项都有可执行的核查办法；只有在实际版本中得到失败回归，才能升格为已复现代码缺陷。优先检查 H01/H02，因为它们涉及 “已通过准入的早期结论，是否会被后续证据重新约束”。

4.1　H01 ｜后到证据是否重新约束已经形成的专家票?

优先级：P0　状态：未验证　执行任务：T06

疑点来源。准入要求考虑全部相关可见事实；专家又会按调度顺序较早形成最终票。文档没有给出 “最后一次全局证据归并后重验所有票” 的实现细节。[R §8.1–8.4，PDF 18–20 页；§6.4，PDF 16 页；§12，PDF 26–27 页]

怎么检查。检查 workflow、evidence_policy、voting 的最终调用顺序。用自有抽象性质的两个充分、同身份、同完整范围但互斥的模拟证明：先支持再反对，反向顺序也执行。

正确行为。新产品两种顺序均返回 CONFLICT/UNKNOWN，不保留先到证据的优势；无关范围的反对事实不能误伤已有充分证明。若已有全局重验，则只补回归，不重写。

4.2　H02 ｜ E5 的 fast 是否错误地把票数封闭当成证据集合封闭?

优先级：P0　状态：未验证　执行任务：T06、T13

疑点来源。固定票序列下，两票多数不能被第三票逆转，结论成立。但第三专家若会产生新的同范围冲突观察，先前两票可能不再通过准入。报告已有 “未完成必需任务不可 fast” 的约束，仍需检查非必需但会改变证据的路径。[R §12.2，PDF 26–27 页；§8.2–8.3，PDF 19 页]

怎么检查。回放两张支持票，并在 slow 分支安排一个产生充分冲突证明的测试工具。比较真实观察流上的 fast/slow，而不只重放固定 ballot；检查 early-stop eligibility 是否显式限定证据闭合。

正确行为。不得声称这种条件下 fast 与 slow 语义等价；新产品默认关闭 fast。旧 E5 保留历史结果，必要时标注保证仅限固定票序列。

4.3　H03 ｜ frozen 外壳下的嵌套容器是否被共享修改?

优先级：P1　状态：未验证　执行任务：T05

疑点来源。原报告已经承认 frozen 不是深层不可变。风险取决于 Candidate 前提、观察 metadata 或共享轨迹里是否仍有可变 list/dict，以及这些对象是否跨任务共享。[R §3.1，PDF 10 页；W1]

怎么检查。在 subject 建立后尝试通过原输入容器和一个共享依赖观察修改嵌套值；比较原 subject、摘要、其他任务视图及序列化快照。另查 model_copy 的浅复制使用。

正确行为。权威快照不随外部别名变化；需要修改时生成新版本。仅 “重算了一次 hash” 不能解决持有旧引用的消费者。

4.4　H04 ｜源码身份、索引身份和运行环境身份是否被混用？

优先级：P1　状态：未验证　执行任务：T09、T05、T11
疑点来源。索引摘要覆盖文档模型与语义元数据，部分适配器才有全文件摘要；执行见证另核源码库存。既可能因仅索引变化造成无谓失效，也可能遗漏未进入切片的真实输入。[R §3.2，PDF 11 页；§5.5，PDF 14–15 页；§10.4–10.7，PDF 23–25 页]
怎么检查。分别改变 helper 文件、模块导入区、适配器版本、检索选中集合、解释器或二进制构件；检查每种变化触发的身份字段与缓存失效。验证摘要检查到实际使用之间的快照一致性。
正确行为。相关源码/环境变化使对应证据失效；同快照内合法改变检索视图不改变源码身份。不得仅凭 Git commit 忽略脏工作树、额外构件或资源文件。

4.5　H05 ｜“最后的累积判断”是否真的累积，而非末任务覆盖？

优先级：P1　状态：未验证　执行任务：T06、T08
疑点来源。文档称专家全部任务结束后，用最后的累积判断形成一票。若跨任务历史裁剪、恢复或摘要遗漏了早期证据，末任务的 UNKNOWN 可能抹掉早期事实，或遗漏早期反证。[R §6.4，PDF 16 页；§7.4，PDF 17 页；§12.3，PDF 27 页]
怎么检查。安排同专家三个无害任务：先支持、再无关未决、最后普通阅读；更换任务顺序，并加入同范围反证变体。查看 evidence 引用集合，而不只比较标签。
正确行为。无关未决不删除充分支持；同范围充分冲突始终可见；一个专家仍只有一票，所有任务成本与原始生产者身份完整保留。

4.6　H06 ｜路径准入是否意外扩成了未计费的范围准入？

优先级：P1　状态：未验证　执行任务：T09
疑点来源。文档强调最终投递路径，但长文件可能只投递局部窗口。工具读取路径、具体 span 与验证器实际分析范围若未分开记录，可能扩大隐藏取证，也可能把被裁剪上下文当成已经审查。[R §3.3，PDF 11 页；§5.3–5.5，PDF 14–15 页；附录 B，PDF 39–40 页]
怎么检查。以一个含两个互不相关函数的自有文件为夹具，只准入一个范围；测试 read_span、callers 和验证器封装是否按照所声明政策拒绝、计费扩展或记录额外读取。
正确行为。取证范围可重建且与 profile 一致；“同路径”不是“整个文件免费”。验证器需要完整范围时明确请求扩展或返回不足，不能静默扩张。

4.7　H07 ｜取消、超时、崩溃和并发下预算是否仍守恒?

优先级：P1　状态：未验证　执行任务：T12
疑点来源。项目已有锁、reservation、fsync 和 request ID 对账，这是正确基础。文档不足以确认 “已预留但未发送”“已发送无响应”“响应落盘前中断” 的全部窗口和日志半行恢复。[R §13.3–13.4，PDF 28 页；§14.2–14.3，PDF 29 页]
怎么检查。仅用 mock 模型传输，在预留、写 start、返回响应、写 usage 等位置注入异常；并发竞争最后一个额度。检查恢复逻辑是否把未知 usage 释放成零，或在不确定已发送状态下自动重发。
正确行为。请求不会因恢复被无授权重发；已发生消耗不丢失，未知用量保持未知；不承诺 provider 不支持的端到端 exactly-once。损坏尾记录与审计异常显式可见。

4.8　H08 ｜源码内容、工具证明与日志中的可信度和敏感性边界是否完整?

优先级：P1　状态：未验证　执行任务：T01、T05、T12
疑点来源。模型允许的数据工具和凭据隔离已存在；文档主要说明当前 API 密钥值脱敏，没有给出所有源码、工具输出和日志读者的敏感信息政策。内容摘要也只证明内容一致，不证明内容真实。[R §5.5，PDF 14–15 页；§7.2，PDF 17 页；§13.2–13.4，PDF 27–28 页]
怎么检查。用自有夹具中的无害指令样式注释、伪造状态字符串和测试用假密钥，验证它们只作为数据；检查 public report、raw journal、归档的访问策略和脱敏边界。
正确行为。源码文本不能变成工具注册、权限或证明；模型自报 CONFIRMED 不能进入权威观察库。公开产物不泄漏测试秘密；原始源码摘要以原始字节计算，展示脱敏不能改变身份算法。

4.9　H09 ｜ LangGraph 步数限制是否与业务预算混淆?

优先级：P2　状态：未验证　执行任务：T07、T13
疑点来源。图执行步数、ReAct 模型步数、规划任务数和工具调用数是不同上限。官方文档说明复杂合法图也可能触发图步数限制，但报告没有给出锁定版本和实际 recursion_limit 配置。[R §6.4–7.1，PDF 16 页；§5.4，PDF 14 页；W2]
怎么检查。读取依赖锁与实际 invoke 配置，用无网络 scripted 模型执行最大合法任务计划及跨专家恢复。记录真实节点迁移数；不要把 8 个任务乘 8 个 ReAct 步骤直接当作图 supersteps。
正确行为。合法最长路径在声明限制内完成；真正无进展循环被有界停止且保留诊断。禁止直接把 recursion_limit 调成任意大数字掩盖调度循环。

5 目标设计：保留可信内核，建立两条互不绑死的交付路径

本章全部属于**拟议设计**，不是对现有实现的描述。它不提供第三方目标的漏洞复现流程，不让模型生成任意命令或自主搜索可利用场景；可执行验证只用于明确注册并获批准的自有无害夹具。项目现有正向见证研究接口可以继续保留，但不成为默认产品主路径。

5.1 默认路径与可选路径

默认静态路径：本地授权源码 → 快照/索引 → 确定性候选发现 → 能力匹配 → 已支持的静态检查 → 全局证据归并 → JSON 与审查报告。

可选验证路径：已批准夹具及其声明条件 → 所需能力 preflight → 受限验证 → 类型化观察 → 同一个证据归并器。环境阻断只影响相关验证与 claim，不删除静态路径已经完成的事实。

可选模型路径：接收已筛选、已脱敏且有引用的静态事实，生成解释和人工复核建议。模型不决定工具是否可用，不修改源码摘要，不设置宿主权限，不授予证明，不把 UNKNOWN 重新命名为 SAFE。解释失败时使用确定性报告模板交付。

这种结构先验证项目有没有一个 “无模型也有产物” 的基线。随后再验证模型是否减少人工复核时间或提高解释质量。它不证明当前规则扫描器已经有足够实用性；若静态报告本身仍不能帮助使用者，应先改线索质量和报告，而不是恢复多层投票掩盖问题。

5.2 建议的最小能力矩阵

输入/性质	默认输出上限	可选升级	明确不承诺
Python 已支持的权限 mode 性质	受限静态性质判断，含精确位置与范围	原有匹配验证器	目录竞态、整体授权或整应用安全
Python 命令构造与可能数据流	事实、可能关联、缺边；满足原准入时的特定静态支持	批准夹具的现有方法	自动远程可利用性、未解析路径安全
Python eval 有界探针	声明模型内输入关系与探针范围	原有匹配探针	任意 Python 执行语义与公开入口权限
授权、其他语言和 fallback	实际适配层级内的结构线索	仅显式支持的已注册方法	由未找到守卫直接推出绕过、通用多语言证明

这些能力上限来自原报告已有边界；实际可用项由 T00/T02 核对，不由本表自动授权。[R §4、§9–10, PDF 12–13、20–25 页]

5.3 一个权威证据模型，多个展示视图

不要再建立一个与现有 `ToolObservation` 平行、但拥有另一套证明语义的大模型。保留现有权威观察和 subject，在应用层增加产品投影。下面是拟议字段职责，不要求逐字照抄所有名称；任何调整必须在 T01 冻结，并保持对应语义。

对象	必须表达的内容	不能承担的职责
ReviewResult	schema/profile/run 身份、阶段状态、findings、缺项、用量与产物引用	不能只留下最终标签，丢掉部分成功

对象	必须表达的内容	不能承担的职责
FindingView	候选、property 版本、位置、scope、证据等级、未覆盖范围、下一步	不能从模式命中自动生成漏洞确认
CapabilityDecision	所需方法、AVAILABLE/UNSUPPORTED/BLOCKED、原因与检查版本	不能把 ready 当作已经验证
Diagnosis	stage、reason_code、owner、retry_policy、required_input、受影响 claim	不能把所有失败归入普通未知
Evidence receipt	原始观察 ID、完整 subject、方法/版本、证明范围、产物摘要、投递状态	hash 只绑定内容，不能证明生产者诚实
Identity bundle	源码、分析器/规范、运行环境、检索视图各自身份	不能用一个易变索引 hash 替代所有身份

结果视图的性质状态建议为 `SUPPORTED / REFUTED / UNKNOWN / CONFLICT`，运行状态单独为 `COMPLETED / PARTIAL / BLOCKED / FAILED / CANCELLED`。原研究模式的 `VULNERABLE / SAFE / ABSTAIN` 与 `CONFIRMED / REFUTED / UNRESOLVED` 保持原义，不直接逐字段改名；由版本化 adapter 映射，并拒绝不合法映射。

例如，一项命令验证由于环境阻断，但源码阅读已经完成，产品应显示 `run_state=PARTIAL`、相关 `property_state=UNKNOWN`、诊断为环境缺项。它不是 “整个仓库无价值”，也不是 “仓库安全”。没有调用工具的能力拒绝可以合法形成应用层 BLOCKED，不需要为了符合专家 vote schema 虚构一次工具尝试。

界面示例：只说明形状，不代表已经运行

```
{
  "schema_version": "product-review-v1",
  "profile_id": "product_triage_v1",
  "run_state": "PARTIAL",
  "finding": {
    "candidate_ref": "demo-candidate-001",
    "property_id": "chmod-mode-others-write",
    "property_state": "UNKNOWN",
    "scope": "declared-statement-scope",
    "evidence_refs": ["demo-observation-001"],
    "application_security": "NOT_ASSESSED",
    "missing_obligations": ["mode value not established"]
  },
  "accounting": {"model_requests": 0}
}
```

这是拟议视图的缩略示例，不是完整可验证 schema；生产结果必须还带有已冻结的身份、来源、范围、诊断和产物字段。`demo-*` 引用不能进入真实审查结果。若没有该观察，schema 校验之外的引用完整性检查必须失败。

5.4 证据归并的确定性规则

输入不是模型文字，而是受信运行时已经登记的观察及其完整契约。先核身份与方法版本，再检查 property、scope、前提、执行与证书状态；只有通过这些检查的观察才能支持性质结论。private telemetry 保留审计和停止功能，但不能因为存在私有完整结果，就绕过公共证书的准入契约。现有 compact 思路应复用，而不是废弃。[原设计依据：R §7.3、§8、§10.8，PDF 17–20、25 页]

归并器先处理同一声明对象上的充分互斥证明。仅当两份证明确实针对同身份、同前提和同完整范围，并声称互斥性质时，返回 CONFLICT。不同独立路径的安全事实与危险事实可以共存，局部事实不能代替全范围结论。复杂范围包含关系第一版宁可要求规范字段精确匹配，也不能写一个模糊字符串相等或自然语言 scope 比较器。

在既定方法和范围内，一个完整存在性支持不应被另一无关 UNKNOWN 删除；反之，一份全范围否定证明若仍留有相关未解析副作用，就不成立。所有既有任务产生的相关观察必须在最终归并时统一约束结果，避免早到结论永久冻结。模型的 supporting/counter/unresolved 引用角色仍可作为解释信息，但不能通过换角色排除不利事实。

证据闭合只指本次声明合同要求的检查已经完成，不是穷尽世界上所有可能证据。若允许 early stop，必须明确相对于哪个已封闭的证据集合保证性质，不能以 “两票够了” 声称与会新增证据的 slow 路径全等。第一产品版本直接关闭这项复杂优化，待 H01/H02 的回归通过后再决定是否值得恢复。

5.5 控制状态机与责任人

当前状态/事件	下一状态	责任与必须保存的内容
源码/配置不合法	BLOCKED 或 FAILED	精确输入错误；不能产生安全结论
能力检查缺少批准依赖	BLOCKED	环境责任人、缺失能力、已有静态结果
缺少真实业务前提	WAITING_INPUT	使用者补项；原 subject 不被模型改写
能力与批准输入完整	READY → RUNNING	运行时负责执行和原始观察登记
验证器完成但语义未决	FINISHED + UNKNOWN	gap、方法、范围、完成状态分开保存
可选验证失败	静态路径继续、整体 PARTIAL	不降低该验证所需的证据门槛
预算不足/无进展	有界终止	已发送请求、未解析原因和部分产物
获得充分证据	FINISHED + 对应性质状态	由确定性归并器判断，模型只解释

表中的 WAITING_INPUT 是任务控制态；整个 run 是否等待或先交付 PARTIAL，由产品 profile 冻结。报告生成必须有确定性兜底路径，不能因模型未给出合格 final JSON 就遗失已经登记的事实。任何自动恢复都不得扩展权限、换目标或生成新的利用场景。

5.6 预算、投递与身份的三个接口

预算接口。对必需观察先做可行性检查：设第 i 个必需证书的最小完整封装为 m_i，最后诊断/输出预留为 r，总观察预算为 B；至少应满足 $\sum_i m_i + r \le B$。满足只是必要条件，不是模型成功保证。未满足时在规划阶段返回具体不足，不执行后再靠截断牺牲证明。模型请求数、reported tokens、字节与物理 worker 消耗继续分别计账。

投递接口。producer result、certificate delivery 和模型解释是三件事。原始结果不可因后续裁剪被重写；只有完整且匹配的证书可以进入对应产品证明视图。已有证书重投递允许复用生产者身份，但必须计费，不能算一次新见证。去重不应把 “需要重新展示已知结果” 错误等同为 “必须再运行目标”。

身份接口。建议保存 `source_digest`、`analysis_contract_digest`、可选 `execution_digest` 和 `retrieval_view_revision`。源码身份覆盖被声明为输入的真实字节集合；分析身份覆盖适配器、规则和规范；执行身份覆盖解释器、已批准依赖/构件、资源和隔离政策；检索视图只是当前可见范围。它们可以在更高层组成 composite identity，但不能混用。对脏工作树、非源码资源和 native 构件，要明确是否属于输入、如何绑定；未绑定就不能宣称已覆盖。

6　实施任务书：一次只完成一个可验收变更

所有路径默认相对 `src/cv_agent/`，测试路径相对仓库根。标为 “建议新增” 的文件当前不保证存在；执行模型必须先用 T00 的实际定位映射。任务卡中的接口和命令都是拟议实施目标，不能假装已经能在当前仓库调用。

主路径顺序： T00 → T01 → T02/T05 → T03/T06 → T04/T09 → T07 → T08 → T12 → T13 → T14。并行只适用于没有依赖且文件不冲突的任务。T10/T11 是受批准的可选环境分支：默认静态产品不等待它们；声明启用相应能力时，它们就是发布前置，而不是可以跳过的测试。

每项完成都要提交可审查变更、失败到通过的回归记录、未解决项与实际命令输出。没有源码时只能生成任务计划，不能将任何任务标成 DONE。已有正确实现应复用，不能为满足任务名重复建设。

兼容不等于保留缺陷。历史产物不可改写；无缺陷的旧语义控制应保持。但 H 类风险若被实际复现且违反 C1–C6，就必须修复共享逻辑，不能只在新产品外面包一层、让错误路径继续默认开放。此时应记录受影响结果、明确算法/模式新版本，经审查更新错误的 golden 期望；旧产物保留用于解释，不再冒充修复后实验。

6.1　T00 ｜建立可核验的源码基线和问题定位表

优先级：P0　前置：无　关联：D12、D14

输入与边界。用户提供的实际仓库快照、安装说明与锁文件；有权限的既有日志。仅有本 PDF 时，此任务状态应为 BLOCKED_INPUT。

允许修改。只读核查仓库、依赖锁、现有 CLI、测试和原始运行产物；新增审查记录，不修改检测逻辑。

1. 记录 HEAD、脏工作树清单、Python 和锁定依赖版本；不得把报告基线自动当作本地实际版本。
2. 逐一核对本报告提到的模块、函数和配置，生成 “报告位置 → 实际文件/符号” 映射；标明不存在或已变化的入口。
3. 收集现有测试清单、skip/xfail 及依赖原因，保存已有失败；不读取受保护评价标签，不调用真实 provider。
4. 为 H01–H09 各写一条复现方案；能排除的条目标为 NOT_REPRODUCED 并记录证据，不为了符合本报告强行造缺陷。

交付物。 audit/baseline.json、audit/issue-map.md、原始测试收集日志。路径为建议新增。

验收。每项已知符号都有实际定位或明确缺项；模型请求 0；工作树没有未经说明的改动。未取得源码不允许提交 “已修复” 结果。对应回归：A01。

停止/回滚。不修改历史实验与参考标签；发现版本与报告不一致时先更新定位表，暂停依赖错误定位的任务。

6.2　T01 ｜冻结产品结果契约，保留研究标签语义

优先级：P0　前置：T00　关联：D07、D09、D13、H08
输入与边界。第 5 章的数据契约和已核对的现有模型；E1–E5 的历史结果样本仅用于兼容测试。
允许修改。domain/review.py、domain/validation_protocol.py；建议新增 domain/product_result.py 与 schema 快照测试。

1. 建立版本化 ReviewResult、FindingView、CapabilityDecision 与结构化 Diagnosis；复用现有 subject、观察和 usage 类型，不复制一套权威证据模型。
2. 把运行状态、性质判断、证据方法和展示状态分开；普通模式线索只能进入 review lead，不能映射成已确认漏洞。
3. 给 property 建立机器可读的 scope、量词、适用条件与不覆盖项；现有 command-execution 标识不能无版本改义。
4. 实现 legacy adapter：旧 profile 原样输出旧字段，新 profile 生成新视图；未知 schema 或非法状态组合直接拒绝。

交付物。类型模型、JSON schema、两份不含漏洞载荷的示例结果、compatibility tests。
验收。示例可序列化再解析；不匹配 property/subject 被拒；UNKNOWN 不会转换成 SAFE；未涉及已复现语义缺陷的旧 E 系列 golden 输出保持兼容；已确认缺陷按任务书的版本化修复规则处理。对应回归：A02、A03、A04。
停止/回滚。若必须更改旧枚举或旧语义才能实现，停止并提交独立迁移提案；不得静默覆盖历史结果。

6.3　T02 ｜实现能力矩阵和任务特定的 preflight

优先级：P0　前置：T01　关联：D01、D03、D13
输入与边界。语言 ×property×scope× 方法矩阵、操作系统能力、批准环境清单与选择的产品 profile。
允许修改。harness 能力声明、runtime 现有检查；建议新增 application/preflight.py，不依赖评价标签。

1. 分开静态检查能力、注册夹具能力和可选模型摘要能力；逐项输出 AVAILABLE、UNSUPPORTED、BLOCKED 及 reason_code。
2. 按实际请求的能力计算 required_checks，不因为可选 native 或 witness 不可用就让静态分析整体失败。
3. 静态路径只读源码；需要无害入口检查时只接受批准的自有 fixture ID，不动态执行未注册仓库。
4. 将 native 构件缺失、隔离不支持、入口功能失败分类；所有检查结束前不发模型请求，不把 readiness 写成证明成功。

交付物。 CapabilityDecision 列表、PreflightReport、无网络测试夹具。
验收。纯静态审查在未配置模型和 witness 时仍可用；要求不可用能力的任务被精确阻塞；补齐已批准依赖后恢复，不变更其他能力状态。对应回归：A05、A06。
停止/回滚。禁止自动联网装依赖、放宽读写根或换解释器；检查需要的资源不在清单中时交还使用者。

6.4 T03 ｜交付不依赖模型的最小端到端审查入口

优先级：P0 前置：T01、T02 关联：D07、D11、D12
输入与边界。本地已授权源码目录和 product_triage_v1 profile；不接受任意外部目标自动执行。
允许修改。cli.py、agents/discovery.py、现有检索/静态工具；建议新增 application/service.py 与 presentation/report.py。

1. 在现有 CLI 上新增产品子命令，调用薄应用服务完成快照、索引、发现、适用静态检查和结果导出。
2. 默认关闭 planner、Jev、多专家、early stop 和执行见证；模型解释必须是之后的独立可选步骤。
3. 通过现有工具与 subject 接口调用检查，不在 presentation 中重新解析源码或补充证明；为解析失败和未处理候选保留计数。
4. 使用临时产物文件加原子提交输出 result.json 和 report.md；零候选也输出有效文档；任何失败保留此前事实与运行状态。

交付物。可从 CLI 触发的应用服务、结果导出、tests/test_application_smoke.py。命令名称以 T00 实际 CLI 体系为准。
验收。从空产物目录运行自有样例，生成可阅读报告及合法 JSON；API key 缺失不影响默认路径；provider mock 断言调用次数为 0；不导入 evaluation 的数据与历史状态。对应回归：A07、A08、A09。
停止/回滚。若无法复用现有 Pipeline，先保留新 service 为独立窄路径；不为统一入口大规模移动 witness 或 evaluation。

6.5 T04 ｜建立诊断码、doctor 和等待输入状态

优先级：P0 前置：T02、T03 关联：D01、D04、D07
输入与边界。原 F1–F6 分类、现有 ValidationPreparation 与新增 Diagnosis 类型。
允许修改。 domain/validation_protocol.py、application/preflight.py、CLI doctor、报告渲染。

1. 每条诊断固定 stage、reason_code、retry_policy、owner、required_input 和阻塞的 claim；原 F1–F6 保留为实验归因，产品诊断码通过映射关联。
2. 实现不收费的 doctor：显示源码读取、解析器、配置、所选能力和模型配置存在性，不做真实 provider 探测。
3. 将缺少人工业务前提映射为 WAITING_INPUT；将已知环境限制映射为 BLOCKED；语义未知保持 FINISHED+UNKNOWN。
4. 为重复无效动作和无进展状态提供有限收尾；展示下一步责任人，不自动生成新的目标场景。

交付物。诊断目录、doctor 输出 schema、人类可读提示与恢复测试。
验收。 F4 不显示为模型推理失败；准备缺项不算 validator_completed；不读取凭据值到报告；用户能从诊断直接看出应修环境还是补业务信息。对应回归：A10、A11。
停止/回滚。不得把所有异常统一捕获为 ABSTAIN；未知异常保留内部错误类别和受控日志引用。

6.6　T05 ｜加固权威快照与分层身份

优先级：P1　前置：T01　关联：H03、H04、H08
输入与边界。 T00 中实际序列化算法和 T01 的身份字段；不得为了简化而删除当前 source_sha256。
允许修改。 tools/identity.py、domain 对象、code_adapters 全文件摘要与已有 runtime 快照接口。

1. 明确 source identity、analysis identity、execution identity 和 retrieval view revision 的职责；每个字段给出输入集合与版本。
2. 在权威边界保存深复制后的规范快照；对参与身份的集合使用不可变表示或受控构造，不共享可修改引用。
3. 规范化 JSON 键顺序、编码、数值和路径；拒绝非有限数与不允许的路径形式。旧摘要算法保留版本，不无声更换。
4. 增加相关输入漂移、外部别名修改和合法检索扩展的差分测试；原始观察 ID 标识物理执行，不用 manifest hash 替代。

交付物。版本化 identity spec、构造函数/适配器修补、tests/test_identity_snapshot.py。
验收。改变相关源码或批准环境会失效；改变单纯展示顺序不改变 source identity；同 manifest 的两次执行具有不同 producer ID；所有旧身份正反控制保留。对应回归：A12、A13、A14。
停止/回滚。摘要规则变化必须走显式 schema 迁移；发现旧结果无法判定算法版本时拒绝混用，不猜测兼容。

6.7　T06 ｜实现全局证据归并，隔离模型投票与性质结论

优先级：P0　前置：T01、T05　关联：D08、D09、H01、H02、H05
输入与边界。已有可信 ToolObservation、proof scope、全部相关可用观察及第 5 章准入规则。
允许修改。 agents/evidence_policy.py、agents/workflow.py、agents/voting.py；建议新增 product reducer；若 H 项确有缺陷，按版本化规则修复共享逻辑。

1. 先用纯函数测试复现 H01/H05；检查是否已有等价全局逻辑，存在则复用。
2. 在产品 profile 中对最终权威观察集合统一求值；引用别名、角色数量和模型 confidence 不参与证明强度。
3. 对同身份、同完整范围的充分互斥证明返回 CONFLICT；局部安全与其他独立危险路径不误判为同范围冲突。
4. 模型解释只能引用 reducer 输出，不能改变性质状态；产品 early stop 默认关闭，旧 E5 仍标明固定票保证的边界。

交付物。纯 reducer、带范围的冲突诊断、基于模拟合法证明的顺序不变性测试。
验收。支持/反对观察调换顺序结果不变；一份证据复制三次不变强；未知观察不自动推翻独立充分证明；不匹配 scope 一律不能升级为目标性质结论。对应回归：A15、A16、A17、A18。
停止/回滚。若现有证明对象不支持精确比较，先采用规范字段完全匹配，复杂包含关系返回未解析；不要自行实现不受限语义等价推断。

6.8　T07 ｜修正计划依赖与确定性协议推进

优先级：P0　前置：T02、T04、T06　关联：D04、D05、D13、H09
输入与边界。能力矩阵、现有 ValidationPlan、状态机和不含目标载荷的 scripted 夹具。
允许修改。 agents/plan_policy.py、agents/planning.py、agents/workflow.py、agents/react.py。

1. 逐条检查 policy 中的 witness 前置依赖，标注其真正数据需求与所约束 claim；独立静态任务不得无故等待可选执行。
2. 将协议完整性、验证器完成和任务终止分别保存；环境阻塞与人工缺项由控制器路由，而非依赖模型猜下一条工具调用。
3. 对无进展状态按已冻结上限收尾；恢复只能使用显式批准的补充输入，不自动搜索新的漏洞复现场景。
4. 测量最大合法计划的真实图迁移数，按锁定版本设置合理限制并保留业务预算；循环异常不能靠任意增大上限解决。

交付物。依赖语义说明、局部 policy 修改、状态转换表、最大计划与无进展测试。
验收。可选任务阻塞不删除独立静态结果；必需验证未完成不能确认该 claim；已完成但 UNRESOLVED 可满足协议依赖而不产生证明；所有路径有有限终点。对应回归：A19、A20、A21、A31。
停止/回滚。禁止通过删除必需义务或放宽 evidence_policy 来制造 completed；改变旧实验计划需另命名 profile。

6.9　T08 ｜实现预算可行性与证书投递分离

优先级：P1　前置：T01、T07　关联：D06、H05
输入与边界。默认字节预算、已有 compact 契约、最小合法证书模板；不得把字节当 provider token。
允许修改。 tools/registry.py、agents/react.py、预算对象与 witness_response 的通用投递适配。

1. 给必需工具声明可验证的最小 public certificate 尺寸边界；规划前序列化检查总预算是否可行。
2. 先预留必需证书与诊断空间，再分配可选观察；借用预算必须保持同专家/全局总量守恒，并写分配事件。
3. 物理执行去重保持原逻辑；新增已有观察的受预算约束投递路径，缓存 ID 与 producer ID 不变。
4. 分别保存 producer state、certificate delivery state 与模型解释状态；外层证书仍被裁剪时不得用于强 claim。

交付物。 allocation plan、delivery receipt、cache-redelivery 记录与精确字节测试。
验收。 D06 的构造性反例可在 8192 字节内完成；超预算提前拒绝；重复投递不增加物理执行计数但增加投递字节；私有原始产物不能绕过公共证明契约。对应回归：A22、A23、A24。
停止/回滚。无法给出有限证书上界的工具先保持可选或显式不可行；不静默提高默认预算，也不抹除诊断与引用字段。

6.10　T09 ｜建立显式静态上下文扩展与范围计账

优先级：P1　前置：T03、T05　关联：D10、H04、H06
输入与边界。已授权源码根、静态审查 profile、source identity 和独立 retrieval view revision。
允许修改。retrieval/context.py、retrieval/dependencies.py、tools/repository.py、admission 记录。

1. 保持 E1–E5 固定检索；只在新产品中接受带理由的静态扩展请求。
2. 使用已有边界读取逻辑，对路径、span、授权根和预算校验；任何新增投递都记录为独立范围准入事件。
3. 优先读取已明确依赖的缺失上下文，但没有解析依据时只记录 UNKNOWN，不能把同名函数强连成调用边。
4. 将检索评分、实际文档数、字节和缺边分别导出；扩展不能触及评价标签或受保护实验输入。

交付物。 ReadGrant/范围清单、静态扩展适配、E 系列冻结回归。
验收。允许的 helper 扩展能减少可测上下文缺项且实际计费；拒绝的扩展保持明确 gap；同路径未准入范围不被免费读取。对应回归：A25、A26。
停止/回滚。遇到需要扩大源码根或读取受保护目录的请求立即停止，不把 “检索不足” 当作扩权限授权。

6.11　T10 ｜修复批准夹具的私有 scratch 能力

优先级：P0（仅启用执行能力时）　前置：T02、T04、T05　关联：D02
输入与边界。经使用者批准的新隔离 profile；自有无害临时文件夹具；现有只读与进程清理测试。
允许修改。 runtime/fixture_isolation.py、runtime/witness/isolation_policy.py、worker 生命周期与资源配置。

1. 先通过失败用例确认正常临时目录需求与只读策略的冲突，不修改目标业务代码绕过需求。
2. 由可信运行时分配每 worker 独立 scratch，固定允许用途、资源和清理策略；不得接收模型给出的宿主路径。
3. 在真实隔离层限定写入，不只设置环境变量；检查继承描述符、并发隔离和各退出路径。
4. 将该能力绑定进 execution identity；原只读 profile 不变，未接受的读取/写入提案仍保持未接受。

交付物。 worker-private-scratch-v1 profile、生命周期代码和正反控制。
验收。仅自有无害功能测试通过；外部写入拒绝；超时/异常无残留；新 profile 的环境检查通过不等于任何候选性质得到确认。对应回归：A27、A28。
停止/回滚。任何边界负控制失败都关闭新 profile；不得放宽全局目录权限来追求正控制通过。

6.12　T11 ｜增加可选的可信原生构件准备链

优先级：P1（可选后续）　前置：T02、T05　关联：D03、H04
输入与边界。获批准的自有小型扩展包、离线依赖仓、固定工具链和构建清单；不默认重建第三方样本。
允许修改。现有 preparation 组装接口、专用构建服务适配和 runtime 构件身份；不放入 ReAct 工具。

1. 在专用受限构建环境区分 metadata、wheel、native artifact 与运行时导入产物。
2. 对构建输入、工具链、输出摘要、ABI、平台和资源文件建立 manifest；构件进入运行环境前做一致性检查。
3. 使用一个只返回常量的批准扩展完成端到端加载测试；源码从声明快照读取，native 产物从匹配构件读取。
4. 缺依赖或无法复现时显式 BLOCKED；不得自动换成已安装的另一份源码或另一版本 wheel。

交付物。构件准备接口、build manifest、可重复的无害构建/加载测试。
验收。匹配构件可加载；错误摘要、ABI 和源码版本被拒绝；构建缓存命中仍核对身份。没有此能力时产品支持矩阵如实保持不支持。对应回归：A29。
停止/回滚。不得声称 pip 的 build isolation 就是安全执行边界；需要额外联网、系统包或权限时暂停等待明确批准。

6.13　T12 ｜验证门禁、预算与事件恢复的失败路径

优先级：P1　前置：T03、T08　关联：D11、H07、H08
输入与边界。原 live 门禁契约、mock HTTP provider、持久化测试目录；不使用真实凭据。
允许修改。 runtime/admission.py、model.py、budget.py、journal.py、脱敏与事件汇总。

1. 为门禁进度、准备耗时和模型耗时分别记录事件；不改变现有进程内 gate 语义。
2. 在预算预留、model start、发送、响应和 usage 持久化窗口注入异常，验证恢复不重复收费调用。
3. 并发竞争最后一个请求额度；对已发送无响应的请求保留未知用量和不确定性，不释放为零。
4. 用假密钥和源码敏感字段验证公开产物与私有日志的边界；记录截断或损坏尾日志，不默默忽略审计异常。

交付物。崩溃注入测试、预算对账报告、阶段耗时字段和诊断文案。
验收。同进程只准入一次且源码漂移拒绝；失败请求仍计数；非法 JSON 有 usage 仍入账；取消后没有新请求；异常不能被映射成 SAFE。对应回归：A30、A32、A33、A34。
停止/回滚。保留原始异常与日志，不自动换 provider 或静默重试；无法确定是否发送的请求交由显式恢复政策处理。

6.14 T13 | 用完整用户路径验收，不以单元测试数量结项

优先级：P0 前置：T04、T06、T07、T08、T09、T12 关联：D01、D07、D08、D14、H02、H09
输入与边界。第 7 章 A01–A34 矩阵；全部自有无害夹具；固定语言与性质支持范围。
允许修改。 tests 的应用路径组、产品 profile 验收、CLI 与产物验证。

1. 从空产物目录调用真实产品 CLI，不直接绕过入口调用内部 helper。
2. 覆盖正常、未知、零候选、解析失败、环境阻塞、模型格式错误、同范围冲突和预算耗尽；检查 JSON 与人类报告一致。
3. 保留完整 pytest 为真实模型准入前置；发布能力另审查必要集成测试，相关 skip/xfail 不视作该能力通过。
4. product_triage_v1 的必需用例全部通过；启用 scratch/native 时追加 T10/T11 的门槛，否则明确显示这些能力未提供。

交付物。 acceptance.json、无网络端到端日志、支持矩阵、演示输入和可读结果。
验收。没有 “把不支持项删掉后全通过” 的分母处理；所有强性质结论可追到充分证据；所有异常可追到诊断；新旧 profile 可分别回归。对应回归：A01–A34（按启用能力选择必需项）。
停止/回滚。基础静态路径未稳定前，不启动新的昂贵模型试验或多专家优化；正反控制任一失败则该 capability 不可发布。

6.15 T14 | 冻结新的产品与模型增量评估

优先级：P1（核心交付后） 前置：T13 关联：D14、D08
输入与边界。事前冻结的自有/获授权审查样本、未泄漏的评价材料、基线产品输出和单独批准的模型预算。
允许修改。 evaluation 新的独立产品协议与使用者评估；保留原 G-A 和全部历史产物。

1. 先比较同一静态审查流程中 “无模型报告” 与 “可选模型解释”，其他能力、上下文与预算保持明确可比。
2. 记录使用者完成复核所需时间、报告事实错误、缺项定位能力、请求数与全部墙钟；不把主观 confidence 当正确概率。
3. 新增 planner、Jev 或多专家前，要求它们在相同任务上显示可重复的净收益；回放节省与 live 成本分开报告。
4. 研究泛化使用新的独立材料与仓库级统计单位；受污染历史材料只作开发回归，不变更原 G-A=NO。

交付物。预登记协议、分母与统计单位说明、paired review 记录、保留/删除组件的决策。
验收。未测得增量时如实停止相关复杂度；不能以更多调用、更长报告或某一次开发正例替代用户价值。对应回归：GP3、GP4；不以源码单测代替使用者评估。
停止/回滚。出现评价材料泄漏、未授权请求或记账缺项时停止研究结论发布；已完成产品功能与其研究资格分开保留。

7 回归规格与发布门槛

7.1 回归矩阵的使用方式

下面 34 项是**建议新增或核对的验收规格，不是本次已经执行的测试结果**。优先复用现有 T01–T16 与相关用例；缺少的边界再补，不要把已有测试换名后计作新增覆盖。全部验证使用自有无害代码、mock 传输与批准夹具，不需要第三方漏洞载荷或外部利用目标。

每条测试至少断言三层：操作状态、性质结果、成本/来源。只检查 `assert result is not None`、只看最终 label 或只看子进程退出码，都不足以验证本报告指出的问题。正控制与负控制应一起通过；为了让正控制跑通而破坏边界负控制，不算修复。

编号	测试主题	必须断言	任务
A01	基线与兼容	实际版本、测试清单、旧 profile 输出可追溯；不存在的文件标缺项。	T00
A02	状态合法性	所有允许的运行状态与性质状态组合可往返序列化；非法组合拒绝。	T01
A03	性质绑定	相同 CONFIRMED 但 property/subject 不同，不能被接受为目标证明。	T01
A04	有限范围	权限位或 callback 的证明不能生成 “整个应用安全/远程可利用”。	T01
A05	静态能力独立	未配置模型与 witness，纯静态路径仍为 AVAILABLE。	T02
A06	准备缺项	缺必需依赖先 BLOCKED，模型请求 0；补齐后无害预检通过。	T02
A07	真实 CLI 冒烟	空产物目录到合法 JSON/报告，完整应用入口，provider 调用 0。	T03
A08	零候选与解析失败	两种情况分别报告；损坏文件不从扫描分母静默消失。	T03
A09	部分成功导出	可选模型或执行失败，已完成静态事实仍出现在最终产物。	T03
A10	归因分离	F4 显示环境阻塞；F1 显示准备/协议缺项，均不能形成安全票。	T04
A11	等待与恢复	缺人工输入进入 WAITING_INPUT，批准补项可恢复；未准备不算验证完成。	T04
A12	嵌套别名	外部输入或共享观察被修改，不改变已封存的权威 subject。	T05
A13	身份失效	helper/导入区/批准构件漂移使对应证据失效，合法视图扩展不改源码身份。	T05
A14	生产者身份	同 manifest 两次执行计 2；同观察三份引用计 1。	T05
A15	晚到冲突	先支持后反对与反向顺序均为同范围 CONFLICT；两票后新增冲突纳入归并，产品不提前返回支持。	T06
A16	独立路径	局部安全事实不抵消另一条已完整建立的性质支持。	T06
A17	复制与置信度	复制观察、换 citation、增加专家 confidence，不提高证据强度。	T06
A18	累积而非覆盖	末任务无关 UNKNOWN 不删除早期充分证据，早期反证也不得遗漏。	T06
A19	数据依赖	可选验证失败不阻塞独立源码检查；真正数据依赖仍阻塞。	T07
A20	完成语义	完成 +UNRESOLVED 可解锁协议依赖；准备或传输失败不可假装完成。	T07
A21	无进展终止	重复无效动作在冻结上限内结束，保留全部请求与拒绝原因。	T07
A22	均分反例	2500+1000+1000+1000 字节合法封装可在 8192 总预算内完成。	T08
A23	证书截断	引用和外层 JSON 计费；证书不完整不能进入强 claim。	T08
A24	缓存重投递	重投递增加字节、不增加物理执行；预算不足时仍拒绝。	T08
A25	受控扩展	批准范围内缺失的无害 helper 可读且计费；超预算拒绝。	T09
A26	路径不等于范围	只准入一段文件，不免费提供另一段；旧 E 系列检索边界不变。	T09
A27	scratch 正反控制	私有临时目录正常读写，工作区外拒绝；不测试第三方目标。	T10
A28	scratch 生命周期	并发隔离、超时、异常和取消后无残留；缺隔离能力拒绝。	T10
A29	native 身份	自有常量扩展匹配构件可加载，错 ABI/摘要/版本拒绝。	T11

编号	测试主题	必须断言	任务
A30	live 门禁	同进程授权调用只完整准入一次；源码漂移、门禁失败拒绝后续请求。	T12
A31	最长合法图	最大合法任务计划可结束；真实循环有限退出，步数分别计量。	T07
A32	用量与并发	mock 并发争最后额度不超发；非法内容但有 usage 的响应仍计费。	T12
A33	崩溃与取消	半写日志、已发无响应和取消均保留不确定性，不自动重发。	T12
A34	数据与敏感边界	注释和伪状态只作数据；假秘密不进入公开产物，权威证明不能由模型自报。	T12

7.2 新的 GP 门槛：与原 G-A 完全分开

以下数字是本次提出的工程验收口径，不是项目成绩，也不是对修复速度的承诺。实施前可由负责人调整一次并冻结；看到结果后不得为了过关修改阈值、删除样本或把必需用例改成 skip。

门槛	必须满足	失败时的动作
GP0：有稳定产物	真实 CLI 完成无模型静态主链；正常、零候选、解析失败、能力缺项都生成合法可读产物；默认路径模型请求 0	只修 T01–T04，不启动新模型试验
GP1：状态与证据可靠	所启用能力对应的 A01–A34 必需用例全部通过；旧准入正反控制保留；强 claim 可追到完整证据	停止发布相关能力；不得降证据门槛
GP2：批准执行能力可用	启用 scratch/native 时，无害功能正控制、边界负控制、身份与清理测试全部通过	能力保持未提供或 BLOCKED；静态主链可独立交付
GP3：实际审查有价值	事前选择一组真实的自有/授权审查任务；记录人工复核时间、事实错误与可行动性；与无工具/原流程配对比较	改线索质量与输出，不堆多专家
GP4：模型有可测增量	在相同静态能力与数据上比较有/无模型；新增成本与质量收益均报告，并允许结论为 “无收益”	保留简单版本，停用无增益模块

核心集成用例的 skip/xfail 不能证明该能力通过。pytest 的正常绿色汇总可以包含这些状态，因此发布验收应单独检查 “本次启用能力所要求的用例是否真正运行并通过”。这与原报告对可选真实 checkout 测试的警告一致。[R §17.1，PDF 34 页；W8]

7.3 先做什么，暂时不做什么

第一阶段：交付闭环。完成契约、能力检查、薄应用服务与诊断；用一个自有样例从真实 CLI 得到报告。此时不要同时重构 LangGraph、换检索算法、升级模型或重新构建外部样本。

第二阶段：证据与控制可靠性。完成身份、全局归并、依赖、预算投递与失败恢复；落实 H01/H02 的顺序与早停反例。若某 H 项被证伪，保留回归即可，不能为了 “审查必须找到 bug” 改坏原逻辑。

第三阶段：按需求增加环境能力。只有实际需要批准的执行能力时，才合入 T10/T11。环境恢复之后先重跑无害功能预检，不立刻用更多模型调用替代基础设施验收；它也不自动救回历史 G-A。

第四阶段：验证价值，之后才优化。比较确定性策略与可选模型解释，再决定 planner、Jev、三专家与 early stop 是否值得保留。复杂度必须对应一个被测得的收益，而不是 “设计上可能更强”。原报告对 Jev 的 accepted/applied、固定回放与真实 live 成本的区分继续使用。[R §11–12、§15.3，PDF 25–27、31 页]

7.4　指标必须保留完整分母

业务输入总数记为 $N_{requested}$，成功产出有效静态报告的数量为 N_{report}，输入或环境阻塞分别计数。至少报告 `report_delivery_rate = N_report / N_requested`；零候选但合法完成的报告可算交付，解析失败或能力缺项必须同时显示其覆盖限制。不要把所有不支持任务从总分母删掉后宣称 100% 可用。

性质证据还应分别记录：发现候选数、支持该性质的方法可用数、实际完成验证数、充分证据数、正确接纳数、冲突数、未决数。各转换率同时带分子/分母，不能把 “环境就绪后的成功率” 冒充 “所有用户输入的成功率”。研究指标沿用原报告对 Coverage、StrictRecall、Precision 和不同 FPR 分母的区分；只有正例参考时，不报告可估计的 FPR。[R §14.4–15，PDF 29–31 页]

成本报告至少拆出五项：环境准备、完整测试门禁、检索/静态工具、模型、结果生成；同时给出总墙钟。reported tokens 缺失就标未知，不写 0。72 次请求属于调用账本，不能变成独立样本量；同仓库多入口、配对版本和多次模型尝试也不能当作相互独立观测。[R §13、§15–16，PDF 27–28、30–33 页]

人工价值用配对任务记录：完成一次复核所需时间、错误事实数量、使用者是否能定位下一步、是否需要重新手工检索。建议先做小规模使用者验收以发现流程缺陷，再决定统计研究样本量；本报告不预设一个看似科学但没有依据的 “准确率达标值”。

7.5　不能作为修复方式的捷径

降低 quorum 或放宽 evidence_policy 来制造正例；把 UNRESOLVED 改名 SAFE；全局开放临时目录或自动安装依赖；让模型生成并反复试探第三方场景；只提高步数和 token；把旧数据换目录重称 held-out；只展示成功格子；凭旧门禁日志直接发送新请求。这些都没有修复本报告识别的根因，有些还会破坏项目已经正确建立的边界。

8　交给执行模型的工作指令

8.1　可直接复制的总指令

> 你在修复 cv-agent。先阅读本报告与 T00 产物。只执行当前指定的一张任务卡，不同时重写全系统。原 E1–E5、C1–C6、T01–T16、历史 G-A、实验结果、评价标签与真实模型授权均不得被静默修改。开始前列出该任务的真实输入、实际文件/符号、依赖状态和允许变更范围。报告中的建议新增路径不是已经存在的 API；找不到必须先报告，不要凭文件名臆造调用。
> 对 H 类问题先写最小无害失败回归并运行。若未复现，说明现有哪段逻辑已覆盖，保留正反控制，不强行改代码。对明确功能缺口先写验收测试再做最小实现。
> 每项修改保持运行状态、性质判断、证据范围、投递状态与用量分离。未知不能改安全，准备不能算验证完成，模型文字不能成为权威证明，引用副本不能成为新物理观察。
> 所有测试默认离线，使用项目自有无害夹具和 mock provider。不得自动下载目标、读取受保护标签、生成漏洞利用数据、扩大宿主权限、切换 provider 或发送真实模型请求。遇到需要新资源或授权的步骤立即暂停并列出缺项。
> 完成后提交修改列表、失败回归、修复后测试、旧行为兼容检查、剩余风险与实际日志路径。只有测试真正通过才能标记完成；只生成了方案或无法执行时标记 BLOCKED/NOT_RUN。新一轮真实模型实验仍须通过项目原完整门禁并获得明确授权。

8.2　每次提交必须返回的记录

```
{
  "task_id": "Txx",
  "status": "DONE | BLOCKED | NOT_REPRODUCED | NOT_RUN",
  "actual_baseline": "verified commit and worktree status",
  "changed_files": [],
  "behavior_before": "observed, not guessed",
  "behavior_after": "observed, not promised",
  "tests": [
    {"command": "exact command", "exit_code": 0,
     "log_path": "actual local artifact"}
  ],
  "legacy_compatibility": "checked or explicitly not checked",
  "model_requests_started": 0,
  "remaining_gaps": [],
  "required_approval": []
}
```

上述是交付记录模板，`exit_code=0` 只是结构示例，执行者必须填入实际结果。不得将模板中的通过值复制成测试证据。测试数量增加是正常现象，不能硬编码 “必须仍是 2562”。

8.3　源码到位后的第一轮操作

以下命令只用于读取基线与运行项目自己的离线测试；本次未执行。先确认当前工作目录为正确仓库，依赖已按原锁文件准备，测试没有未经批准的外部行为。`--no-sync` 不负责补装缺失依赖；缺项应报告。

```
git status --short
git rev-parse HEAD
uv run --no-sync pytest --collect-only -q
# New test file: create it under T03 before running this command.
uv run --no-sync pytest tests/test_application_smoke.py -q
# Full regression remains necessary before any authorized live run.
uv run --no-sync pytest -ra --durations=20
```

真正的产品子命令名称、参数与安装入口应由 T00 确认后在 T03 实现。本报告没有把猜测的 `cv-agent review ...` 命令包装成今天已经可用的功能。若只提供原技术报告而没有仓库，第一轮正确输出就是源码与配置缺项清单，不是伪造补丁或测试日志。

9　来源索引与最后结论

9.1　项目来源 R

R：用户提供的《cv-agent 技术报告：当前系统设计、逻辑与流程》，2026-09-30，43 页。文中 “PDF 页” 均指原文件的物理页，不是正文页脚数字；原报告正文页 1 对应 PDF 页 7。

文件 SHA-256：

`0e4c69cc71e8b38083b63f20a63e88f3ba56a3e3b72f285f28e31780eb41d29a`

本次核对主题	原报告定位
定位、身份、状态与分层	§1–3，PDF 7–12 页
发现、检索、可见范围与预算	§4–5，PDF 12–15 页
计划、任务依赖、ReAct 与收尾	§6–7，PDF 15–18 页
证据准入、冲突与语义契约	§8，PDF 18–20 页
静态工具、夹具与隔离	§9，PDF 20–22 页
见证、入口、环境与紧凑投递	§10，PDF 22–25 页
Jev、quorum、早停和共享观察	§11–12，PDF 25–27 页
传输、门禁、usage 与日志	§13，PDF 27–28 页
评价分离、指标与成本	§14–15，PDF 28–31 页
K/M/E 实验与 G-A	§16，PDF 32–34 页
测试、能力边界与后续工作	§17–18，PDF 34–36 页
文档复现、模块和工具定位	§19、附录 A–D，PDF 37–41 页

原报告参考文献中的源码、测试契约和 `.hermes` 文件，本次仅通过 R 转引，没有独立访问。事实更新必须以实际源码和原始记录核验，不应把本报告的推断写回为历史事实。

9.2　官方技术资料 W1–W8

检索日期：2026-09-30。只用于机制核验，不作为项目完成证明。标题在 PDF 中可点击；实施时仍核对项目实际版本。

W1：Pydantic 官方文档：Models / Faux immutability。核对 frozen 外壳与嵌套 dict 仍可变的差别；不证明项目已经发生共享修改。官方文档。

W2：LangChain 官方文档：GRAPH_RECURSION_LIMIT。核对图步数错误与合法复杂图也可能触限；实际行为以项目锁定版本为准。官方文档。

W3：Linux 内核文档：Landlock userspace API。核对路径权限、写入/截断及已有描述符等边界；不假设项目一定使用 Landlock。官方文档。

W4：Linux 内核文档：Seccomp BPF。核对系统调用过滤不是完整沙箱；隔离设计需要多层边界。官方文档。

W5：Python 3.12 官方文档：tempfile。核对临时目录选择与清理行为；环境变量不能替代实际访问控制。官方文档。

W6：pip 官方文档：Build System Interface。核对构建依赖、metadata 和 wheel/native 构建是不同阶段。官方文档。

W7：PyPA 官方指南：Packaging binary extensions。核对二进制扩展对平台、解释器和构建环境的依赖。官方文档。

W8：pytest 官方文档：skip and xfail。核对绿色测试套件可包含未运行或预期失败项；已启用能力需要独立必要测试准入。官方文档。

9.3　最后结论

这个项目的首要修复方向，是让确定性工程承担确定性职责，让模型只承担能够被明确评价的增量工作。源码绑定、证据准入、未知处理与记账不是应该拆掉的负担；真正需要调整的是过长的必经链、过晚暴露的环境缺口、与证据强度没有必然关系的投票依赖，以及尚未独立验收的用户交付层。

先拿到真实源码并核实风险；随后用无模型主路径完成一次真实可读交付；再修全局证据、依赖、预算与恢复；必要时增加批准环境能力；最后测量模型和多专家是否值得存在。这样每一步都能用输入、输出、测试和停止条件验收，而不再依靠 “再加一层 agent 也许就会成功”。

本次交付是一份有来源、有优先级和可执行任务规格的文档级审查。它不声称项目已经修复，也不保证所有待验证风险一定存在。原始的 G-A=NO 应被诚实保留；新的可用性必须由新的完整用户路径证明。